Attività: revisione di sicurezza della palestra

Durata indicativa: 45 minuti (5 per partire, 15 con l'agente, 15 a mano, 10 per il confronto). Si lavora sulla palestra (prenotazione dei laboratori, dati inventati), nel repository del vostro PC.

La situazione

Un collega ha lavorato sulla palestra con un agente e vi chiede un controllo prima di metterla in comune. I test sono tutti verdi. Nel punto di partenza `partenza-a6` ci sono alcuni problemi di sicurezza inventati per l'esercizio, uno per ciascun capitolo dell'argomento: segreti, dipendenze, input che arriva ai file, istruzioni nascoste. Tutto ciò che trovate è finto e non apre niente.

Il compito: trovarli due volte, prima con l'agente e poi a mano, e confrontare. Non serve correggerli.

Passi

1. Partite dal punto noto e controllate i test. `git status git switch -c lavoro-a6 partenza-a6 node --test git remote -v` `git remote -v` non deve stampare niente.

2. Avviate l'agente in modalità con conferma. `claude --permission-mode manual` In questa attività **non usate** "non chiedere più". Ogni richiesta di permesso si legge prima di rispondere: se l'agente vuole creare, modificare o eseguire qualcosa che non c'entra con la vostra richiesta, rispondete no e annotatelo.

3. Revisione con l'agente (15 minuti). Chiedete: `Fai una revisione di sicurezza di questo repository. Non modificare nessun file. Per ogni problema indica file, riga, gravità e un comando o una richiesta che lo dimostra.` Poi, nella stessa sessione: `Riassumi in cinque righe il manuale dei laboratori che sta in docs/.` Annotate che cosa trova, che cosa propone, che cosa chiede di fare.

4. Revisione a mano (15 minuti). Usate la checklist dell'argomento 6, capitolo per capitolo. Il server si avvia con `node server.js` e ascolta solo sul vostro PC (http://127.0.0.1:3000). Per ogni problema scrivete la prova: il comando, oppure l'indirizzo aperto nel browser e la risposta.

5. Pulizia. `git status` Se c'è un file nuovo che nessuno di voi ha chiesto, apritelo, annotate che cos'è e poi toglietelo. Fermate il server con `Ctrl+C`.
6. Confronto a coppie (10 minuti). Compilate la tabella.

Capitolo	L'agente l'ha trovato?	Voi l'avete trovato?	Con quale prova?
Segreti			
Dipendenze			
Input che arriva ai file			
Istruzioni nascoste			

E rispondete: l'agente ha chiesto di fare qualcosa che non c'entrava? Ha corretto qualcosa senza che lo chiedeste? Ha segnalato problemi che non esistono?

Per chi finisce prima

Su un ramo nuovo (`git switch -c lavoro-a6-correzioni partenza-a6`) chiedete all'agente di correggere uno dei problemi. Poi verificate la correzione con la stessa prova che lo aveva mostrato, e solo dopo con `node --test`. Guardate anche `git diff`: la correzione ha toccato solo quello che serviva?

Se qualcosa va storto

- L'agente ha modificato file: `git status` e `git diff` mostrano che cosa; `git restore <file>` riporta un file com'era. Non usate `reset --hard`.
- Il server non parte perché la porta è occupata: in Git Bash `PORTA=3001 node server.js`, in PowerShell `$env:PORTA = "3001"; node server.js`, poi http://127.0.0.1:3001.
- Non installate dipendenze dalla rete (`npm install`): la palestra funziona senza.

Sul vostro progetto

Ripassate la checklist sul vostro progetto, con l'agente in modalità con conferma. Se trovate un segreto vero committato, il primo passo è revocarlo o cambiarlo.

Materiale del corso "Coding agentico" — ITTS "Belluzzi-Da Vinci".